

CO2-PART II

NAME: Sri Janani B

REG NO:192421036

QUESTION:

Threat Modeling of Enterprise Applications Using the STRIDE Methodology

ANSWER:

Abstract

Enterprise applications manage critical organizational data such as customer information, financial records, employee details, and business operations. As cyber threats continue to evolve, identifying security vulnerabilities during the software design phase has become essential. Threat modeling is a proactive security technique that helps developers identify potential threats before implementation. This case study demonstrates how the STRIDE methodology developed by Microsoft can be applied to an enterprise web application to identify security threats, assess risks, and recommend appropriate mitigation strategies. The study shows that integrating threat modeling into the Software Development Life Cycle (SDLC) significantly improves application security while reducing future remediation costs.

1. Introduction

Modern enterprise applications handle confidential business information and are constantly exposed to cyber attacks. Attackers target vulnerabilities such as authentication flaws, insecure APIs, privilege escalation, and data leaks.

Threat Modeling is a structured process used to identify security threats during software design. One of the most widely adopted threat modeling approaches is Microsoft's STRIDE methodology, which categorizes threats into six security classes.

This case study applies STRIDE to analyze an enterprise employee management application and demonstrates how security risks can be identified and mitigated before deployment.

2. Objectives

The objectives of this case study are:

- Understand the concept of Threat Modeling.
- Study Microsoft's STRIDE methodology.
- Analyze an enterprise application architecture.
- Identify possible security threats.
- Recommend security controls.
- Improve secure software development practices.

3. Background

Enterprise applications are large-scale software systems used by organizations for business operations.

Examples include:

- Employee Management Systems

- Banking Applications
- Hospital Management Systems
- ERP Systems
- E-Commerce Platforms

These applications process sensitive information and therefore require strong security measures.

Traditional security testing often occurs after development, whereas threat modeling identifies vulnerabilities during the design phase.

4. Enterprise Application Overview

Case Study Application

Employee Management System (EMS)

Features

- Employee Login
- HR Dashboard
- Payroll Management
- Attendance Tracking
- Leave Management
- Admin Panel
- Reports

Users

- Employee
- HR Manager
- Administrator

Technologies

Frontend:

- React.js

Backend:

- Spring Boot

Database:

- MySQL

Authentication:

- JWT Authentication

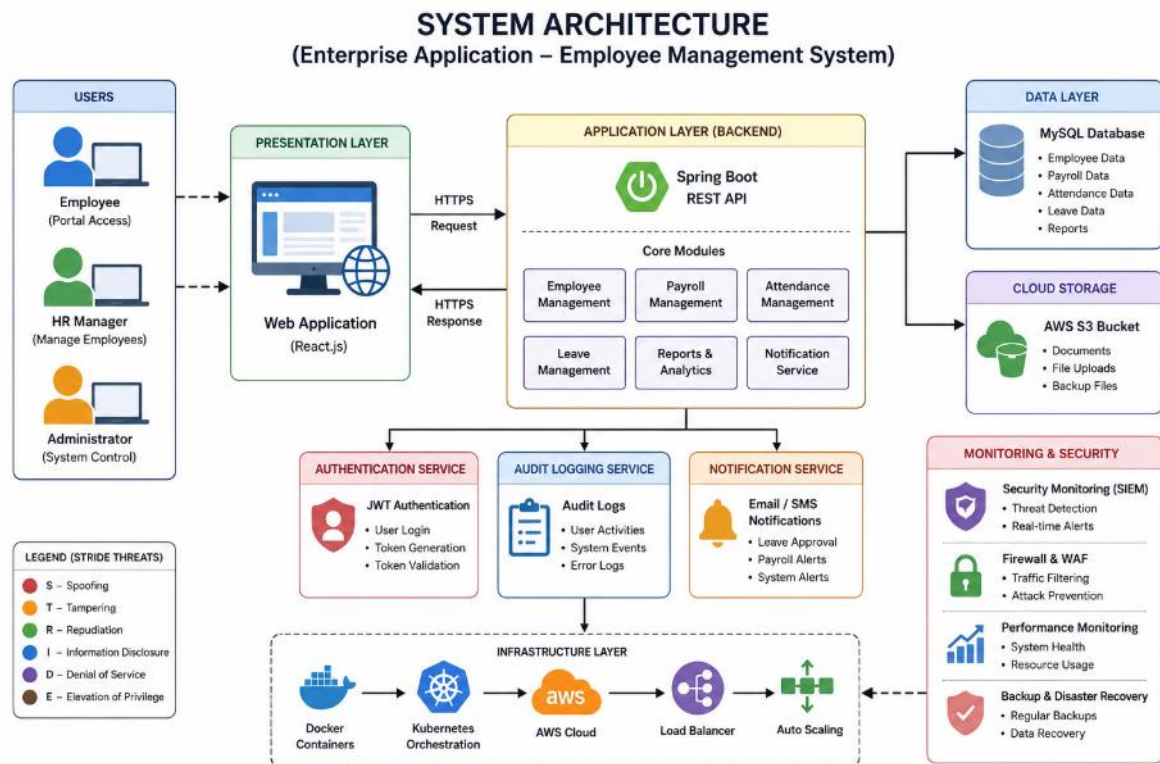
Deployment:

- Docker + Kubernetes

Cloud:

- AWS

5. System Architecture



Components

Client Browser



Web Server



Application Server



Authentication Service



Database Server



Cloud Storage

Data Flow

1. User logs in.
2. Authentication verifies credentials.
3. JWT token generated.
4. User accesses services.
5. Application retrieves data from database.
6. Logs stored for monitoring.

6. STRIDE Methodology

STRIDE is Microsoft's threat modeling framework.

Threat	Description
--------	-------------

Spoofing	Pretending to be another user
Tampering	Unauthorized modification of data
Repudiation	Denying performed actions
Information Disclosure	Exposure of confidential information
Denial of Service	Making the application unavailable
Elevation of Privilege	Gaining unauthorized permissions

7. Threat Identification

7.1 Spoofing

Possible Threat

An attacker steals employee login credentials.

Impact

Unauthorized access.

Example

Credential stuffing attack.

Risk

High

7.2 Tampering

Possible Threat

Attacker modifies payroll records.

Impact

Incorrect salary processing.

Risk

Critical

7.3 Repudiation

Possible Threat

Administrator deletes employee data and denies performing the action.

Impact

No accountability.

Risk

Medium

7.4 Information Disclosure

Possible Threat

Database backup becomes publicly accessible.

Impact

Employee personal information exposed.

Risk

Critical

7.5 Denial of Service

Possible Threat

Large number of fake requests overwhelm the server.

Impact

Application unavailable.

Risk

High

7.6 Elevation of Privilege**Possible Threat**

Employee gains administrator access.

Impact

Full system compromise.

Risk

Critical

8. Risk Assessment

Threat	Likelihood	Impact	Risk Level
Spoofing	High	High	High
Tampering	Medium	Critical	High
Repudiation	Medium	Medium	Medium
Information Disclosure	High	Critical	Critical
Denial of Service	Medium	High	High
Elevation of Privilege	Low	Critical	High

9. Mitigation Strategies**Spoofing**

- Multi-Factor Authentication (MFA)
- Strong password policy
- JWT expiration
- Account lockout

Tampering

- Input validation
- Digital signatures
- Database integrity constraints
- Secure APIs

Repudiation

- Audit logging
- Time-stamped logs
- Centralized log monitoring
- Immutable logging

Information Disclosure

- HTTPS/TLS encryption
- Database encryption
- Role-Based Access Control (RBAC)
- Secure API authentication

Denial of Service

- Rate limiting
- Web Application Firewall (WAF)
- Load balancing
- Auto-scaling

Elevation of Privilege

- Least privilege principle
- RBAC
- Secure session management
- Access token validation

10. Results and Discussion

Applying STRIDE to the Employee Management System successfully identified multiple security threats before deployment. Information Disclosure and Elevation of Privilege were identified as the most critical risks due to their potential to expose sensitive employee data and grant unauthorized administrative access. Implementing mitigation strategies such as Multi-Factor Authentication, Role-Based Access Control, encryption, audit logging, and rate limiting significantly reduced the application's attack surface. This case study demonstrates that integrating threat modeling early in the SDLC helps developers build secure applications, lowers remediation costs, and strengthens organizational security.

11. Best Practices

- Perform threat modeling during the design phase.
- Apply the principle of least privilege.
- Encrypt sensitive data in transit and at rest.
- Implement secure authentication mechanisms.
- Conduct regular security testing.
- Monitor logs continuously.
- Keep software dependencies updated.
- Integrate threat modeling into the DevSecOps pipeline.

12. Conclusion

Threat modeling is a proactive approach that enables organizations to identify and address security risks before software deployment. The STRIDE methodology provides a systematic framework for analyzing threats related to authentication, data integrity, accountability, confidentiality, availability, and authorization. In this case study, applying STRIDE to an Employee Management System highlighted several potential vulnerabilities and corresponding

mitigation techniques. By incorporating STRIDE into the SDLC, organizations can reduce cyber risks, improve software quality, and strengthen the overall security posture of enterprise applications.

13. Future Scope

- Integrate STRIDE with DevSecOps pipelines.
- Automate threat modeling using security tools.
- Incorporate AI-based threat prediction.
- Enhance cloud-native application security.
- Adopt Zero Trust Architecture.
- Continuously update threat models based on emerging cyber threats.